

MODUL PEMBELAJARAN

Pertemuan 3: Metodologi dan Standar Penetration Testing

Mata Kuliah Penetration Testing (KSI251522) — Semester 5

Mata Kuliah	Penetration Testing
Program Studi	Sarjana Terapan Keamanan Sistem Informasi, Politeknik Negeri Bengkalis
Dosen Pengampu	Nurmi Hidayasari
Sub-CPMK	01.1 — Mampu mengidentifikasi tahapan metodologi pengujian penetrasi berdasarkan standar yang berlaku.

1. Capaian Pembelajaran

Indikator Capaian (sesuai RPS):

- Ketepatan menjelaskan tahapan PTES, NIST SP 800-115, OWASP WSTG, dan OSSTMM.
- Ketepatan memetakan tahapan standar terhadap kebutuhan pengujian pada kasus yang diberikan.

2. Pendahuluan

Pada Pertemuan sebelumnya, Anda telah mengenal siklus pengujian keamanan yang paling sederhana: **Plan** → **Discover** → **Attack** → **Report**. Siklus empat fase ini mudah diingat, tetapi terlalu sederhana untuk benar-benar dijalankan di lapangan — ia tidak menjelaskan secara rinci apa yang harus dilakukan pada tiap fase, siapa yang bertanggung jawab, atau bagaimana hasilnya harus didokumentasikan.

Modul ini membahas empat metodologi/standar yang mengisi kekosongan tersebut: PTES, NIST SP 800-115, OWASP WSTG, dan OSSTMM. Ditambah satu framework pelengkap, MITRE ATT&CK, yang bukan metodologi pengujian tetapi kerap dipakai berdampingan dengannya. Setelah mempelajari modul ini, Anda diharapkan mampu menjelaskan tahapan tiap standar dan memilih/mengombinasikan standar yang tepat untuk suatu kebutuhan pengujian — keterampilan yang akan langsung dipakai mulai Pertemuan 4 saat menyusun dokumen perencanaan pengujian yang sesungguhnya.

3. Uraian Materi

3.1 Mengapa Pentest Membutuhkan Metodologi Baku?

Tanpa metodologi baku, setiap pentester bisa mendefinisikan “pengujian yang lengkap” secara berbeda-beda. Akibatnya, hasil pengujian sulit dibandingkan antarproyek, sulit diaudit, dan sulit dipercaya klien. Dengan metodologi baku:

- Klien tahu persis tahapan apa yang akan dikerjakan dan kapan.
- Auditor/regulator dapat memverifikasi bahwa proses pengujian sudah menyeluruh.
- Tim dapat bekerja secara konsisten walau personelnnya berganti.

Poin pentingnya: seorang pentester profesional umumnya perlu mengenal lebih dari satu standar, karena tiap standar dirancang untuk menjawab kebutuhan yang berbeda — sebagian mengatur struktur keseluruhan proyek, sebagian lain mengatur detail teknis satu jenis target.

3.2 PTES — Penetration Testing Execution Standard

PTES adalah kerangka **lifecycle** yang paling banyak dipakai untuk mendefinisikan struktur keseluruhan sebuah engagement pentest, dari kontak pertama dengan klien hingga laporan akhir. PTES terdiri atas tujuh fase berurutan:

1. Pre-engagement Interactions — tahap paling menentukan secara hukum. Di sinilah scoping meeting dilakukan, kontrak dan Rules of Engagement (RoE) disepakati, serta estimasi waktu dan biaya ditentukan. Kesalahan pada fase ini (scope yang ambigu, RoE yang tidak lengkap) akan berdampak ke seluruh fase berikutnya.

2. Intelligence Gathering — reconnaissance pasif dan aktif terhadap target: OSINT, pemetaan organisasi, footprinting jaringan/domain, hingga media sosial. Tujuannya membangun peta permukaan serangan (attack surface) sebelum menyentuh sistem secara langsung.

3. Threat Modeling — mengidentifikasi aset paling bernilai dan skenario ancaman yang relevan berdasarkan hasil intelligence gathering. Fase ini membantu tim memprioritaskan area mana yang paling penting diuji lebih dulu.

4. Vulnerability Analysis — menemukan celah keamanan melalui kombinasi pemindaian otomatis (automated scanning) dan pengujian manual, termasuk memverifikasi temuan untuk menyaring false positive.

5. Exploitation — mencoba mengeksploitasi kerentanan yang ditemukan secara terkendali, untuk membuktikan bahwa dampaknya nyata — bukan sekadar potensi di atas kertas. Seluruh aktivitas di fase ini tunduk pada batasan yang disepakati dalam RoE.

6. Post-Exploitation — menilai dampak bisnis dari akses yang berhasil diperoleh: data apa yang bisa diakses, seberapa jauh potensi pergerakan lebih lanjut (lateral movement) di dalam sistem — tetap dalam batas yang diizinkan RoE.

7. Reporting — mendokumentasikan seluruh proses, temuan, bukti (evidence), tingkat risiko, dan rekomendasi mitigasi ke dalam format yang dapat dipahami dan ditindaklanjuti oleh klien.

Status saat ini: standar inti PTES statis sejak versi 1.1 (2014) dan tidak direvisi secara resmi lagi. Namun demikian, PTES tetap menjadi rujukan struktur lifecycle paling umum di industri, dan dijaga tetap relevan oleh komunitas melalui dokumen

“PTES Technical Guidelines” serta berbagai “Field Manual” buatan praktisi yang menerjemahkan tujuh fase di atas menjadi checklist dan rekomendasi tools yang lebih mutakhir.

3.3 NIST SP 800-115

NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment) diterbitkan oleh National Institute of Standards and Technology, Amerika Serikat, dan berorientasi pada kebutuhan kepatuhan (compliance) serta pelaporan formal ke instansi. Strukturnya terdiri atas empat fase:

1. Planning — mendefinisikan tujuan, ruang lingkup, dan aturan keterlibatan (setara Pre-engagement pada PTES, tetapi dibahas lebih ringkas).

2. Discovery — menggabungkan information gathering dan scanning/identifikasi kerentanan dalam satu fase.

3. Attack — memvalidasi kerentanan melalui percobaan eksploitasi terkendali (setara Vulnerability Analysis + Exploitation pada PTES, digabung menjadi satu fase).

4. Reporting — pada NIST SP 800-115, pelaporan ditekankan sebagai aktivitas yang berjalan berkelanjutan sepanjang proses, bukan hanya di fase akhir.

Status saat ini: belum direvisi sejak diterbitkan tahun 2008. Kelebihan utamanya adalah format pelaporan yang bersifat *prescriptive* (terstruktur ketat), sehingga cocok dipakai saat hasil pengujian perlu diserahkan ke auditor atau regulator. Kekurangannya, detail teknis per jenis target (mis. aplikasi web) tidak dijabarkan serinci OWASP WSTG, sehingga NIST SP 800-115 jarang dipakai sendirian tanpa standar pelengkap.

3.4 OWASP Web Security Testing Guide (WSTG) v4.2

Berbeda dari PTES dan NIST SP 800-115, WSTG **bukan kerangka lifecycle** — WSTG adalah katalog lebih dari 90 test case teknis yang detail, khusus untuk pengujian aplikasi web. WSTG dikelompokkan ke dalam beberapa kategori pengujian, di antaranya:

- Information Gathering
- Configuration and Deployment Management Testing
- Identity Management Testing
- Authentication Testing

- Authorization Testing
- Session Management Testing
- Input Validation Testing (termasuk SQL Injection, XSS, dan variannya)
- Error Handling, Cryptography, dan Business Logic Testing
- Client-Side Testing

Setiap test case dalam WSTG diberi kode unik dengan format WSTG-<KATEGORI>-<NOMOR> (mis. WSTG-INFO-02 untuk pengujian fingerprinting web server), lengkap dengan penjelasan tujuan pengujian, cara melakukannya, dan contoh alat yang relevan.

Status saat ini: aktif dipelihara oleh komunitas OWASP. Versi 4.2 (dirilis 2020) adalah versi stabil terkini; versi 5.0 masih dalam tahap pengembangan. Dalam mata kuliah ini, WSTG dipakai sebagai referensi teknis rinci pada fase Vulnerability Analysis/Attack milik PTES atau NIST — khususnya mulai Pertemuan 10 saat pengujian difokuskan pada aplikasi web.

3.5 OSSTMM 3 — Open Source Security Testing Methodology Manual

OSSTMM, dikembangkan oleh ISECOM, unik karena cakupannya lebih luas dari tiga standar sebelumnya: tidak hanya jaringan dan aplikasi, tetapi juga aspek fisik dan manusia. OSSTMM 3 membagi pengujian ke dalam enam channel keamanan operasional:

- Human Security Testing — pengujian terhadap faktor manusia (mis. social engineering).
- Physical Security Testing — keamanan lokasi fisik (akses gedung, ruang server).
- Wireless Security Testing — keamanan jaringan nirkabel.
- Telecommunications Security Testing — keamanan sistem telekomunikasi.
- Data Networks Security Testing — pengujian jaringan data, area yang paling beririsan dengan PTES/NIST.
- Metrik lintas-channel: Trust Analysis dan Risk Assessment Values (RAV) untuk mengukur tingkat keamanan operasional secara kuantitatif.

Status saat ini: versi terakhir, 3.02, dirilis tahun 2010 dan tidak diperbarui sejak itu. Meski demikian, OSSTMM tetap menjadi satu-satunya rujukan baku yang mencakup aspek fisik dan manusia — dua area yang tidak disentuh PTES, NIST SP 800-115, maupun OWASP WSTG.

3.6 Perbandingan Keempat Metodologi

Dimensi	PTES	NIST SP 800-115	OWASP WSTG v4.2	OSSTMM 3
Cakupan	Umum (lifecycle engagement)	Umum, orientasi kepatuhan	Khusus aplikasi web	Fisik, manusia, wireless, telco, data network
Struktur	7 fase berurutan	4 fase berurutan	90+ test case per kategori	6 channel + metrik RAV
Status	Statis sejak 2014, dijaga komunitas	Tidak direvisi sejak 2008	Aktif, v4.2 stabil	Versi terakhir 3.02 (2010)
Kegunaan utama	Struktur keseluruhan engagement	Format laporan untuk audit	Detail teknis pengujian web	Aspek non-teknis: fisik & manusia

3.7 MITRE ATT&CK sebagai Pelengkap

MITRE ATT&CK **bukan metodologi pengujian** seperti keempat standar di atas — ATT&CK adalah taksonomi taktik dan teknik penyerang (Tactics, Techniques, and Procedures/TTP). Bedanya mendasar:

- **PTES/NIST/WSTG/OSSTMM** menjawab pertanyaan “bagaimana proses pengujian dijalankan?” — mereka mendefinisikan alur kerja, tahapan, dan format pelaporan.
- **MITRE ATT&CK** menjawab pertanyaan “teknik serangan apa ini, dan bagaimana mengklasifikasikannya?” — setiap teknik diberi kode unik (mis. T1190 untuk “Exploit Public-Facing Application”) yang dikelompokkan ke dalam matriks taktik (Reconnaissance, Initial Access, Execution, Persistence, dan seterusnya).

Dalam praktik, ATT&CK dipakai berdampingan dengan salah satu metodologi di atas — misalnya untuk mengklasifikasikan teknik eksploitasi yang berhasil dilakukan pada fase Exploitation (PTES) atau Attack (NIST), sehingga laporan akhir memakai istilah yang dipahami secara luas di industri keamanan siber.

Status saat ini: aktif dipelihara oleh MITRE, dengan rilis terbaru (v19, April 2026) menambahkan teknik-teknik baru sesuai perkembangan pola serangan nyata.

3.8 Mengombinasikan Framework dalam Praktik

Tim pentest yang matang jarang memakai satu standar secara kaku. Sebaliknya, mereka mengombinasikan beberapa standar sesuai kebutuhan tiap tahap dan jenis target. Contoh alur gabungan yang umum dijumpai di industri:

- Gunakan struktur tujuh fase PTES sebagai kerangka keseluruhan proyek (dari kontrak hingga laporan).
- Pada fase Vulnerability Analysis/Attack, rujuk detail teknis OWASP WSTG apabila target berupa aplikasi web.
- Klasifikasikan setiap teknik eksploitasi yang berhasil menggunakan kode MITRE ATT&CK, agar temuan mudah dipahami lintas organisasi.
- Jika klien membutuhkan dokumen audit formal (misalnya untuk kepatuhan regulasi), sesuaikan format laporan akhir dengan struktur NIST SP 800-115.
- Jika ruang lingkup mencakup aspek fisik atau manusia (mis. uji social engineering), tambahkan rujukan OSSTMM yang tidak dimiliki tiga standar lainnya.

Prinsip pemilihan standar bukanlah “mana yang paling baik”, melainkan “mana yang menjawab kebutuhan tahap ini.”

4. Rangkuman

- Metodologi baku membuat hasil pengujian konsisten, dapat diverifikasi, dan dapat dipertanggungjawabkan — tidak bergantung pada preferensi individu pentester.
- PTES menyediakan struktur lifecycle 7 fase yang paling umum dipakai sebagai kerangka keseluruhan proyek.
- NIST SP 800-115 memiliki 4 fase yang lebih ringkas, unggul dalam format pelaporan untuk kebutuhan audit/kepatuhan.
- OWASP WSTG adalah katalog teknis rinci (90+ test case) khusus aplikasi web, bukan kerangka lifecycle.
- OSSTMM adalah satu-satunya standar yang mencakup aspek fisik dan manusia, di luar cakupan tiga standar lainnya.
- MITRE ATT&CK melengkapi keempat standar di atas sebagai taksonomi klasifikasi teknik serangan, bukan sebagai alur pengujian.
- Praktik terbaik industri adalah mengombinasikan beberapa framework sesuai kebutuhan tiap tahap — bukan memilih satu standar secara eksklusif.

5. Tugas Mandiri (Individu)

Sifat tugas: Individu — dikerjakan dan dikumpulkan sendiri-sendiri.

Estimasi waktu: 120 menit (Penugasan Terstruktur + Kegiatan Mandiri)

Format jawaban: esai singkat terstruktur, 1–2 halaman, diketik, dikumpulkan melalui edLink sebelum sesi Pertemuan 4 dimulai.

Bobot: termasuk dalam komponen kognitif Pertemuan 3 (4% dari total nilai mata kuliah, sesuai RPS).

Instruksi: Jawab kelima pertanyaan berikut berdasarkan pemahaman Anda sendiri terhadap materi pada Bagian 3. Jawaban yang hanya menyalin definisi tanpa alasan/analisis sendiri akan dinilai rendah pada aspek “kedalaman analisis”.

1. Jelaskan secara ringkas ketujuh fase PTES. Menurut Anda, fase mana yang paling menentukan keberhasilan sebuah engagement secara hukum? Berikan alasan.
2. Bandingkan NIST SP 800-115 dengan PTES: sebutkan dua perbedaan struktural di antara keduanya, lalu jelaskan satu situasi/skenario di mana NIST SP 800-115 lebih tepat dipakai dibandingkan PTES.
3. OWASP WSTG bukan kerangka lifecycle seperti PTES atau NIST SP 800-115. Jelaskan mengapa perbedaan ini penting, dan pada fase PTES/NIST yang mana WSTG paling relevan digunakan sebagai pelengkap?
4. Berikan satu contoh skenario pentest (boleh nyata atau rekaan) di mana OSSTMM menjadi standar yang wajib dipertimbangkan, sementara PTES, NIST SP 800-115, dan OWASP WSTG saja tidak cukup. Jelaskan alasannya.
5. MITRE ATT&CK sering disebut “bukan metodologi pengujian.” Jelaskan perbedaannya dengan metodologi (PTES/NIST SP 800-115), lalu berikan satu contoh bagaimana MITRE ATT&CK dapat dipakai bersama salah satu dari empat standar lainnya dalam satu proyek pentest.

Rubrik Penilaian (per soal, skala 0–20)

Aspek Penilaian	Bobot/Soal	Kriteria
Ketepatan konsep	0–10	Penjelasan sesuai fakta yang diajarkan (tahapan, status, kegunaan tiap standar), tidak keliru menyebut fase/karakteristik.

Kedalaman analisis/alasan	0–10	Alasan yang diberikan logis, spesifik terhadap skenario yang diajukan sendiri (bukan tempelan definisi umum).
---------------------------	------	---

6. Daftar Pustaka

- The Penetration Testing Execution Standard (PTES). <http://www.pentest-standard.org>
- Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). NIST SP 800-115: Technical Guide to Information Security Testing and Assessment. Gaithersburg: NIST.
- OWASP Foundation. (2020). OWASP Web Security Testing Guide (WSTG) v4.2. <https://owasp.org/www-project-web-security-testing-guide/>
- Herzog, P. (2010). OSSTMM 3: The Open Source Security Testing Methodology Manual. ISECOM.
- MITRE. ATT&CK Framework. <https://attack.mitre.org>